

# Relatório SAST

Análise Estática de Vulnerabilidades em Código Gerado por LLMs

## **Comparativo de Vulnerabilidades**

Código gerado por ChatGPT × Gemini × Claude

5 casos de teste × 4 linguagens

Gerado em 27 de May de 2026

# Relatório SAST Completo

Análise estatística e comparativa de vulnerabilidades em código gerado por LLMs

139 findings totais · 60/60 combinações analisadas

## 1. Visão geral

|                       |                      |           |             |
|-----------------------|----------------------|-----------|-------------|
| TOTAL FINDINGS<br>139 | COMBINAÇÕES<br>60/60 | HIGH<br>1 | ERROR<br>20 |
| MEDIUM<br>24          | WARNING<br>46        | LOW<br>42 |             |

**Sobre este relatório:** os números são contagens de findings (cada ocorrência reportada pelas ferramentas SAST). Veja "Notas metodológicas" ao final para interpretar corretamente.

## 2. Conclusões automáticas

Observações geradas automaticamente dos dados. Use com critério.

### IA COM MENOR MÉDIA GERAL

Considerando todas as combinações analisadas, a IA 'chatgpt' apresentou a menor média de findings SAST por código (2.1; mediana 2.0, desvio padrão 1.55). A IA com maior média foi 'gemini' (2.6 findings em média).

▲ Menos findings não necessariamente significa código mais seguro. Veja notas metodológicas.

### LINGUAGEM COM MENOR MÉDIA DE FINDINGS

Por linguagem, 'typescript' teve a menor média (1.87 findings/código) e 'java' a maior (3.6 findings/código).

▲ Comparações entre linguagens são limitadas porque cada uma é analisada por ferramentas com cobertura diferente (Bandit ~67 regras, SpotBugs ~140, ESLint segurança 16, Semgrep 1000+). Mais regras tende a produzir mais findings, não necessariamente código pior.

### CASO DE TESTE MAIS 'DIFÍCIL'

O caso que produziu mais findings em média foi 'caso03\_upload' (3 achados por código). O caso com menos findings foi 'caso02\_products' (1.58 achados).

▲ Casos diferentes têm superfícies de ataque diferentes — essa variação é esperada e indica que casos com mais ações sensíveis (upload, render HTML, etc.) tendem a gerar mais findings.

### MELHOR IA NO CASO01\_AUTH

No 'caso01\_auth', a IA com menor média de findings foi 'claude' (1.25 achados em 4 códigos analisados).

### MELHOR IA NO CASO02\_PRODUCTS

No 'caso02\_products', a IA com menor média de findings foi 'chatgpt' (1.25 achados em 4 códigos analisados).

### MELHOR IA NO CASO03\_UPLOAD

No 'caso03\_upload', a IA com menor média de findings foi 'gemini' (2.75 achados em 4 códigos analisados).

### MELHOR IA NO CASO04\_COMMENTS

No 'caso04\_comments', a IA com menor média de findings foi 'chatgpt' (1.5 achados em 4 códigos analisados).

### MELHOR IA NO CASO05\_SESSION

No 'caso05\_session', a IA com menor média de findings foi 'chatgpt' (2.5 achados em 4 códigos analisados).

### TIPOS DE VULNERABILIDADE MAIS FREQUENTES EM 'CHATGPT'

Para 'chatgpt', os CWEs mais frequentes foram: CWE-605 (5 ocorrências), CWE-668 (5 ocorrências), CWE-22 (4 ocorrências).

TIPOS DE VULNERABILIDADE MAIS FREQUENTES EM 'CLAUDE'

Para 'claude', os CWEs mais frequentes foram: CWE-605 (5 ocorrências), CWE-668 (5 ocorrências), CWE-522 (5 ocorrências).

TIPOS DE VULNERABILIDADE MAIS FREQUENTES EM 'GEMINI'

Para 'gemini', os CWEs mais frequentes foram: CWE-522 (5 ocorrências), CWE-605 (4 ocorrências), CWE-668 (4 ocorrências).

COMBINAÇÃO COM MAIS FINDINGS HIGH/ERROR

A combinação com mais findings de severidade HIGH/ERROR foi 'caso01\_auth / chatgpt / typescript', com 5 achados nessa faixa.

MAIOR TAXA DE CÓDIGOS SEM FINDINGS

A IA 'chatgpt' teve a maior proporção de códigos sem qualquer finding SAST: 20.0% das combinações analisadas.

▲ Pode indicar tanto código mais seguro quanto código mais simples/abstrato que o SAST não consegue analisar profundamente.

3. Estatísticas por IA

Cada linha agrega todas as combinações de caso × linguagem para essa IA.

| IA      | Códigos | Total | Média | Mediana | Desvio | Mín | Máx | % sem findings |
|---------|---------|-------|-------|---------|--------|-----|-----|----------------|
| chatgpt | 20      | 42    | 2.1   | 2.0     | 1.55   | 0   | 5   | 20.0%          |
| claude  | 20      | 45    | 2.25  | 2.0     | 1.62   | 0   | 5   | 20.0%          |
| gemini  | 20      | 52    | 2.6   | 2.0     | 1.98   | 0   | 7   | 20.0%          |

Verde = menos findings (top 1), amarelo = posição 2, vermelho = mais findings (posição 3).

4. Estatísticas por linguagem

▲ **Aviso metodológico:** linguagens diferentes têm ferramentas com cobertura diferente (Bandit ~67 regras, SpotBugs ~140, ESLint segurança 16, Semgrep 1000+). Não compare linguagens diretamente sem contextualizar.

| Linguagem  | Códigos | Total | Média | Mediana | Desvio | Mín | Máx | % sem findings |
|------------|---------|-------|-------|---------|--------|-----|-----|----------------|
| typescript | 15      | 28    | 1.87  | 1       | 2.0    | 0   | 7   | 26.7%          |
| python     | 15      | 28    | 1.87  | 2       | 0.52   | 0   | 2   | 6.7%           |
| javascript | 15      | 29    | 1.93  | 2       | 2.02   | 0   | 5   | 46.7%          |
| java       | 15      | 54    | 3.6   | 4       | 1.3    | 2   | 6   | 0.0%           |

## 5. Estatísticas por caso

Diferenças entre casos refletem complexidade e superfície de ataque distintas.

| Caso            | Códigos | Total | Média | Mediana | Desvio | Mín | Máx | % sem findings |
|-----------------|---------|-------|-------|---------|--------|-----|-----|----------------|
| caso03_upload   | 12      | 36    | 3     | 3.0     | 1.48   | 0   | 5   | 8.3%           |
| caso05_session  | 12      | 34    | 2.83  | 3.0     | 2.12   | 0   | 6   | 25.0%          |
| caso04_comments | 12      | 30    | 2.5   | 2.0     | 1.78   | 0   | 7   | 8.3%           |
| caso01_auth     | 12      | 20    | 1.67  | 2.0     | 1.37   | 0   | 5   | 25.0%          |
| caso02_products | 12      | 19    | 1.58  | 2.0     | 1.44   | 0   | 4   | 33.3%          |

## 6. Cruzamentos multidimensionais

### 6.1 IA × Linguagem — média de findings por código

| IA \ Linguagem | java         | javascript   | python       | typescript   | Média geral |
|----------------|--------------|--------------|--------------|--------------|-------------|
| chatgpt        | 3.2<br>(n=5) | 1.4<br>(n=5) | 2<br>(n=5)   | 1.8<br>(n=5) | 2.1         |
| claude         | 3.6<br>(n=5) | 2.4<br>(n=5) | 2<br>(n=5)   | 1<br>(n=5)   | 2.25        |
| gemini         | 4<br>(n=5)   | 2<br>(n=5)   | 1.6<br>(n=5) | 2.8<br>(n=5) | 2.6         |

### 6.2 IA × Caso — média de findings por código

| IA \ Caso | caso01_auth   | caso02_products | caso03_upload | caso04_comments | caso05_session | Média geral |
|-----------|---------------|-----------------|---------------|-----------------|----------------|-------------|
| chatgpt   | 2.25<br>(n=4) | 1.25<br>(n=4)   | 3<br>(n=4)    | 1.5<br>(n=4)    | 2.5<br>(n=4)   | 2.1         |
| claude    | 1.25<br>(n=4) | 1.5<br>(n=4)    | 3.25<br>(n=4) | 2.5<br>(n=4)    | 2.75<br>(n=4)  | 2.25        |
| gemini    | 1.5<br>(n=4)  | 2<br>(n=4)      | 2.75<br>(n=4) | 3.5<br>(n=4)    | 3.25<br>(n=4)  | 2.6         |

### 6.3 Linguagem × Caso — média de findings por código

| Linguagem \ Caso | caso01_auth   | caso02_products | caso03_upload | caso04_comments | caso05_session | Média geral |
|------------------|---------------|-----------------|---------------|-----------------|----------------|-------------|
| java             | 2<br>(n=3)    | 3.33<br>(n=3)   | 5<br>(n=3)    | 3<br>(n=3)      | 4.67<br>(n=3)  | 3.6         |
| javascript       | 0<br>(n=3)    | 0<br>(n=3)      | 3<br>(n=3)    | 2<br>(n=3)      | 4.67<br>(n=3)  | 1.93        |
| python           | 2<br>(n=3)    | 2<br>(n=3)      | 1.33<br>(n=3) | 2<br>(n=3)      | 2<br>(n=3)     | 1.87        |
| typescript       | 2.67<br>(n=3) | 1<br>(n=3)      | 2.67<br>(n=3) | 3<br>(n=3)      | 0<br>(n=3)     | 1.87        |

Cor: branco = 0, laranja claro = poucos, vermelho-escuro = muitos. n = códigos analisados.

## 7. Análise por severidade

### 7.1 Severidade por IA

| Categoria | HIGH/ERROR (média / total) | MEDIUM/WARNING (média / total) | LOW/INFO (média / total) |
|-----------|----------------------------|--------------------------------|--------------------------|
| chatgpt   | 0.4 / 8                    | 1 / 20                         | 0.7 / 14                 |
| claude    | 0.1 / 2                    | 1.35 / 27                      | 0.7 / 14                 |
| gemini    | 0.55 / 11                  | 1.15 / 23                      | 0.7 / 14                 |

### 7.2 Severidade por linguagem

| Categoria  | HIGH/ERROR (média / total) | MEDIUM/WARNING (média / total) | LOW/INFO (média / total) |
|------------|----------------------------|--------------------------------|--------------------------|
| java       | 0.13 / 2                   | 0.67 / 10                      | 2.8 / 42                 |
| javascript | 0.2 / 3                    | 1.47 / 22                      | 0 / 0                    |
| python     | 0 / 0                      | 1.87 / 28                      | 0 / 0                    |
| typescript | 1.07 / 16                  | 0.67 / 10                      | 0 / 0                    |

### 7.3 Severidade por caso

| Categoria       | HIGH/ERROR (média / total) | MEDIUM/WARNING (média / total) | LOW/INFO (média / total) |
|-----------------|----------------------------|--------------------------------|--------------------------|
| caso01_auth     | 0.67 / 8                   | 0.5 / 6                        | 0.5 / 6                  |
| caso02_products | 0.25 / 3                   | 0.83 / 10                      | 0.5 / 6                  |
| caso03_upload   | 0.33 / 4                   | 1.92 / 23                      | 0.75 / 9                 |
| caso04_comments | 0.42 / 5                   | 0.83 / 10                      | 0.75 / 9                 |
| caso05_session  | 0.08 / 1                   | 1.75 / 21                      | 1 / 12                   |

## 8. Análise por tipo de erro (CWE)

Common Weakness Enumeration — categorias padronizadas de vulnerabilidades.

### 8.1 Top CWEs por IA

| Categoria | Top 5 CWEs |     |         |                                     |
|-----------|------------|-----|---------|-------------------------------------|
| chatgpt   | CWE-605    | 5 · | CWE-668 | 5 · CWE-22 4 · CWE-522 4            |
| claude    | CWE-605    | 5 · | CWE-668 | 5 · CWE-522 5 · CWE-22 4 · CWE-79 3 |
| gemini    | CWE-522    | 5 · | CWE-605 | 4 · CWE-668 4 · CWE-22 4 · CWE-89 4 |

### 8.2 Top CWEs por linguagem

| Categoria  | Top 5 CWEs |      |         |                         |
|------------|------------|------|---------|-------------------------|
| java       | CWE-23     | 1    |         |                         |
| javascript | CWE-522    | 14 · | CWE-22  | 6 · CWE-89 4 · CWE-79 2 |
| python     | CWE-605    | 14 · | CWE-668 | 14                      |
| typescript | CWE-22     | 6 ·  | CWE-79  | 2 · CWE-89 2            |

### 8.3 Top CWEs por caso

| Categoria       | Top 5 CWEs |      |         |                           |
|-----------------|------------|------|---------|---------------------------|
| caso01_auth     | CWE-605    | 3 ·  | CWE-668 | 3                         |
| caso02_products | CWE-605    | 3 ·  | CWE-668 | 3                         |
| caso03_upload   | CWE-22     | 12 · | CWE-605 | 2 · CWE-668 2 · CWE-23 1  |
| caso04_comments | CWE-89     | 6 ·  | CWE-79  | 4 · CWE-605 3 · CWE-668 3 |
| caso05_session  | CWE-522    | 14 · | CWE-605 | 3 · CWE-668 3             |



## 10. Notas metodológicas

### Como interpretar este relatório

- 1. Menor número de findings ≠ código mais seguro.** Pode significar: (a) código realmente mais seguro, (b) menos código (cobertura funcional menor), (c) padrões não detectados por análise estática, (d) uso de abstrações que escondem vulnerabilidades.
- 2. Comparações entre linguagens são limitadas.** Bandit tem ~67 regras para Python; SpotBugs com find-sec-bugs tem ~140 detectores para Java; ESLint com plugins de segurança tem 16 regras explícitas; Semgrep tem 1000+. Mais regras tende a produzir mais findings, não código pior.
- 3. Comparações entre IAs dentro da mesma linguagem são mais válidas.** Como a mesma ferramenta analisa todos os códigos da mesma linguagem, comparar ChatGPT × Gemini × Claude em Python (por ex) é metodologicamente sólido. Esta é a comparação principal do relatório.
- 4. Tamanho da amostra é pequeno.** São 20 amostras por IA (5 casos × 4 linguagens). Diferenças menores que 1–2 findings na média podem ser ruído. Desvios padrão altos indicam comportamento inconsistente da IA.
- 5. Severidade é definida pela ferramenta, não pelo impacto real.** Um HIGH do Bandit pode ser menos sério na prática que um MEDIUM do Semgrep, dependendo do contexto. Use o CWE para entender a natureza da vulnerabilidade.
- 6. DAST complementa SAST.** Este relatório cobre apenas análise estática. Vulnerabilidades dinâmicas (configuração, runtime, autenticação) requerem o relatório DAST e o relatório combinado.

### Glossário

| Termo                 | Significado                                                                                        |
|-----------------------|----------------------------------------------------------------------------------------------------|
| Finding               | Uma ocorrência reportada por uma ferramenta SAST. Pode ser vulnerabilidade real ou falso positivo. |
| CWE                   | Common Weakness Enumeration — categoria padronizada (ex: CWE-89 = SQL Injection).                  |
| Severidade            | Classificação da ferramenta (HIGH/MEDIUM/LOW). Cada ferramenta usa critérios próprios.             |
| Média                 | Total de findings ÷ nº de códigos analisados.                                                      |
| Desvio padrão         | Mede consistência. Baixo = estável; alto = variável entre códigos.                                 |
| Taxa de zero findings | % de códigos sem nenhum finding.                                                                   |